System Vulnerability Assessment

Understanding SQL Injection

Course Lecturer: P. Mutunda for KMU © 2024

Introduction to Databases

- A database is a logically organised collection of related data.
- It is an organised collection of data stored electronically, designed to efficiently manage, retrieve, and update information.
- Interaction with a Database such as searching a book in a Library catalogue, requesting for school fees balance from a University (Invoice), checking for Account balance in a Bank, Hotel reservations and so on is done through a Database Management System (DBMS), using a special language called Structured Query Language (SQL). It is considered to be a comprehensive language for database creation and manipulation supported by DBMSs such as MySQL, MS Access for Microsoft, Oracle, Sybase and so on.

Uses of Databases

1. **Decision making support:** Databases provide reliable, organised information for reporting, analytics, and business intelligence.
2. **Automation and operational efficiency**: they support applications by managing user information, transactions, inventory, and other daily operations
3. **Data Management:** Databases allow controlled data access, management of concurrent users, and ensure data integrity and consistency.
4. **Efficient data storage and organisation:** Databases store huge volumes of structured data in tables, enabling easy access, update, and retrieval using queries.
5. **Evidence and forensic investigations:** Database forensics helps uncover evidence of illegal activities by analysing database transactions, access logs, and detecting fraud or tampering.

Types of Databases

1. **Relational databases:** stores data in tables with rows and columns, suing SQL for managing data. Relational databases follow ACID properties for reliability and are ideal for structured data. Examples of DBMS that form relational databases include MySQL, Oracle, and Microsoft SQL Server.
2. **NoSQL Databases:** Non-Relational and schema – less, good for unstructured or semi-structured data. Subtypes include document databases such as MongoDB, Key value stores such as Redis, Wide column stores such as Cassandra and Graph databases such as Neo4j.
3. **Cloud databases:** Designed to run in cloud environments, offering scalability. Examples here include Amazon RDS and Microsoft Azure SQL Database
4. **Object Oriented Databases:** Store data as objects including data methods, useful for complex data-models
5. **Network Databases:** Use a graph like structure allowing many-to-many relationships and is useful in complex data scenarios
6. **Hierarchical Databases:** Use a tree – like Parent-child structure, suitable for data with clear hierarchies such as organisational charts

Introduction to Relational Databases

- Relational databases happens to be the most commonly used databases currently.
- Here, data is organised in tables which is made up of rows otherwise known as records and columns otherwise known as fields.

Introduction to MySQL – install MySQL using XAMPP

MySQL DBMS is one of the components that come with XAMPP, an open-source web development package for Microsoft Windows. The package consists of 4 applications namely, Apache web server, MySQL, PHP, and Perl hence the acronym XAMPP.

To install XAMPP. Proceed as follows:

1. Download the latest version of XAMPP from Apache Friends website. The file is a self-extracting archive such as xampp-win32-1.8.1-VC9-installer.exe
2. Double click the file to launch the installer
3. Select the components to install under XAMPP, server, programming language and tools.
4. Select the installation target where the files are to be extracted such as D/Demo/XAMPP, then click the install button. Patiently wait for self extraction process to finish. Follow further instructions

Types of SQL commands

1. **Data Definition Language (DDL):** This involves defining a database which involves specifying the structure, data type and constraints (rules) of the data to be stored in a database. The following are sets of commands used in defining a database;

DDL Cont.

Commands	Description
CREATE	Creates a new database, table view or other objects in a database
ALTER	Modifies structure of an existing database object such as inserting a new field in a table
DROP	Deletes a named database or table and its content. If it is desired that only content is removed without deleting the table, DELETE command is used

SQL Syntax

- When writing / typing SQL commands, it is important to remember a few rules and guidelines in order to construct valid and easy to read statements.
- SQL commands always start with a key word such as CREATE and the entire statement ends with a semicolon (;)
- SQL commands such as CREATE cannot be split across lines meaning that they should not be hyphenated
- SQL commands are not case sensitive meaning for example CREATE and create are the same. However, for the sakes of differentiating, use uppercase for SQL command words in a statement

DDL cont.

- In order to use DDL commands in MySQL, you need to have Admin privileges
- For creating a Database, use the following statements
- CREATE DATABASE KAPASA MAKASA; (a Database called KAPASA MAKASA will be created)

```
CREATE TABLE table_name (
Column1 DATATYPE,
Column2 DATATYPE,
Column3 DATATYPE,
……..,
);
```

DDL cont.

```
CREATE TABLE Customers (
First_Name VARCHAR (25),
Surname VARCHAR (25),
Phone_Num VACHAR (30),
Gender Lookup Wizard,
Town VARCHAR (30)
);
```

PRACTICAL TASK

1. Create a Table in a database named Students with fields as follows;

Practical Cont.

- First Name with 30 characters
- Last Name with 30 characters
- Phone number
- School fees balance
- Address
- Final results
- Status with a proceed to next level statement

2. Create a Table named Lecturers with the following details

Creating a Lecturer Table

```
CREATE Table Lecturer
(
Employee_Num NOT NULL UNIQUE,
FirstName varchar (30),
LastName varchar (30),
Phone varchar (3),
Course_ID int
)
```

Using ALTER command

- Let's assume that the we add a constraint to course ID so that it should not be blank or empty. We can use ALTER command to do this as follows;

```
ALTER Table Lecturers
MODIFY CourseID Int NOT NULL;
```

We can also drop a constraint using ALTER command such as the following;

```
ALTER TABLE Lecturers DROP PRIMARY KEY;
```

To completely delete a database, we use both ALTER and DROP commands together e.g the above SQL stamen

Using DROP command

DROP Database database name;

- This will delete the database

DROP TABLE tablename; would delete a particular table from a database

e.g. DROP TABLE Employees;

SQL Datatypes

- SQL datatypes are used to specify the type of data that can be stored in a database. For example, a name is made of characters. In standard SQL, it can be defined as a **string** of five characters using a datatype known as char of varchar. Make reference to the table below for a few datatypes that could be used.

Datatypes examples

Data type	Description
CHAR (Size)	Fixed length character string which also specifies size in parenthesis., of maximum 255
VARCHAR (size)	Variable – Length character string. Max size is specificized in parenthesis
BIT	Takes a binary value which is either 0 or 1
DECIMAL /FLAOT	Takes a value with decimal places such as 4.1
INT	Numeric value -2,147,483648 and 2,14,483,647
DATE	Stores a date e.g. April 29, 2020
TIME	Stores time e.g. 10:30 PM
TEXT	Variable – length alphanumeric data with maximum length of 2,147,483,647 characters

SQL Constraints

- A constraint is a rule associated with a field or table that ensures accuracy and reliability of data entered into the database. **Column level** constraints are applied on a particular field while **table level** constraints are applied on the whole tale. **NOT NULL** is a column level constraint in a field and its meaning is that the field cannot be left blank. Refer to the table below for some examples on constraints;

SQL Constraints

Constraints	Meaning
NOT NULL	Ensures that a column must contain a value
DEFAULT	Provides a default value for a column when none is specified
UNIQUE	Ensures that all values for a column are unique
PRIMARY KEY	Uniquely identifies a record in a database table. It also enforces NOT NULL constraints
FOREIGN KEY	A column or combination, whose values match a Primary Key in a related table
CHECK	A constraint that ensures that all values in a column satisfy certain conditions

Data Manipulation Language DML

- These are Structured Query Language commands used to manipulate data stored in a Relational Database.
- The following are key words commands in a DML SQL in a table format and what they imply

DML

Commands	Meaning
INSERT	Used to add a new record into a table
UPDATE	This command is used to modify field values of one or more records that match specified criteria in the WHERE clause . Its basic form of the select statement is made of three clauses, UPDATE, SET and WHERE
SELECT	This command is used to retrieve data from the database
DELETE	Used to remove data from the database

Practical

- Using INSERT

INSERT INTO Lecturer

VALUES (‘Jaka’, ‘Ndala’, ‘+26097777777’, ‘CYS330’,);

UPDATE command: we use it to modify field values of one or more records that match specified criteria in the WHERE clause. The basic form of the select statement is made of three clauses namely; UPDATE, SET and WHERE as follows;

UPDATE “TableName’

SET “ColumnName”(fieldname) = “Newvalue”

WHERE <condition>

DML cont.

```
UPDATE Lecturers
SET FirstName = ‘Mwenya’
WHERE EMPLOYEEID = 1212;
```

```
SELECT command
SELECT column 1, Column 2, …
FROM Table_Name;
```

```
SELECT FirstName, LastName
FROM Lecturer;
```

Practical Cont.

- If you want to select all lecturers from the table

SELECT *

FROM Lecturers;

DELET command

- It is used to remove records from table. The basic form of the select statement is made of two clauses DELETE FROM and WHERE
- For example,

DELETE FROM Lecturers

WHERE FirstName = ‘Zacharia’;

- To delete all records from the table called Lecturers, you leave out the WHERE clause
- DELETE from Lecturers;

Data Query Language - DQL

- Used for querying and retrieving data from the database. Its core purpose is to fetch data stored in schema objects such as tables based on specified criteria
- Its main command is the SELECT command in a statement

Syntax

```
SELECT column 1, column 2, column3, ….
FROM tableName
WHERE condition;
```

For example,

```
SELECT Student_Name
FROM Student
WHERE Phone_number = 123456789;
```

Data Control Language – DCL

- It is used to manage permissions and control access to data stored in a database. Its primary purpose is to ensure that only authorised users have the ability to view or manipulate database objects by granting and revolking privileges
- GRANT: This command is used to give specific permissions to users or roles on database objects, such as tables and forms. Permissions can include SELECT, INSERT, UPDATE, DELETE and so on.
- REVOLKE: The command removes previously granted permissions from users or roles, restricting their access to database objects
- DENY (specific to some databases such as Ms SQL Sever): Explicitly denies certain permissions to users or roles, overriding any granted privileges

Practical example

GRANT SELECT, INSERT, UPDATE, DELETE ON Lecturers to User1;

REVOKE INSERT ON Lecturers

FROM User1;

DENY UPDATE On Lecturers

TO user1

Explanation of the above

- The first statement is giving user1 various permissions on the Lecturers table
- In statement 2, the INSERT permission has been revoked from user1
- The third and last statement user1 has completely been denied to update Lecturer table in the database.
- DCL is basically meant for security by controlling who can perform operations on the data, thus protecting sensitive information from unauthorised access while enabling necessary operations by authorised users.

SQL Operations and Wildcards

- Records can be filtered using relational operators, logical operators and the distinct clause
- **Relational operators:** These are Boolean operators used to compare two values such as less than (<), greater than (>), equal to (=) and not equal to (< >)
- **Logical comparisons:** comparisons such as LIKE, AND, OR, NOT, and BETWEEN are used to combine multiple conditions in SQL statements.
- **Distinct:** Keyword used in conjunction with SELECT statement to eliminate duplicate records.

More examples

```
SELECT FirstName, town, final_Results
FROM Students
WHERE Final Results >=50;

SELECT FirstName, Gender, Final_Results
FROM Students
WHERE (Gender = ‘Male’) AND (Final_Results  >= 50);
```

More examples cont.

Wildcard	Description	Example	Meaning
%	This sign is used as a substitute for zero or more characters	Salary LIKE ‘%5’	Display records with salary values that end with 5
_	The underscore is used as a substitute for single character	Salary LIKE ‘_00%’	Displays records with salary that has 0 in the second and third place values

More examples on queries

- SELECT FirstName, Surname, Town

FROM Students

WHERE town LIKE ‘K%’;

SELECT FirstName, Surname, Gender

FROM Students

WHERE FirstName LIKE ‘%s’;

Other tasks – creating a calculated field in a database

- Create a calculated field to show the new balance for students

Linking two or more tables in a Relational Database (Foreign key)

Creating a query from two or more tables

Understanding SQL (SQLi)